UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE

Ingeniería de Software

KunturChat

Salas de chat seguras, vigiladas desde las alturas

Laboratorio 3

Especificación de requisitos y mecanismos de seguridad

Proyecto Integrador

Asignatura: Desarrollo de Software Seguro
NRC: 36900

Integrantes

Altamirano Ricardo
Ayo Alisson
Valencia Yuliana

Sangolquí, Ecuador
Fecha: 15 de octubre de 2026

Índice

1. Introducción y objetivo **2**

2. Contexto y alcance **2**

3. Actividad 1: Requisitos funcionales **2**

4. Actividad 2: Requisitos no funcionales **3**

5. Actividad 3: Requisitos de seguridad **4**

6. Actividad 4: Propiedades de seguridad **6**
6.1. Matriz de análisis de propiedades 6
6.2. Propiedades por requisito funcional 7

7. Actividad 5: Técnicas y mecanismos de seguridad **8**
7.1. Plan de pruebas del esteganálisis 10
7.2. Límites que hay que decir en voz alta 11

8. Actividad 6: Zero Trust, Secure by Design y Shift Left Security **11**
8.1. Controles de ISO/IEC 27001:2022 (Anexo A) 12
8.2. Prácticas de ISO/IEC 27034 (seguridad de aplicaciones) 12

9. Actividad 7: Matriz de trazabilidad **13**

Bibliografía **15**

1. Introducción y objetivo

KunturChat está en etapa de especificación. Este documento da continuidad al *Laboratorio 2* (análisis y tratamiento de riesgos: 15 activos, R01–R15, políticas POL01–POL08) y desarrolla las siete actividades del *Laboratorio 3*: requisitos funcionales, no funcionales y de seguridad; propiedades de seguridad; técnicas y mecanismos; aplicación de Zero Trust, Secure by Design y Shift Left; y matriz de trazabilidad. Todo control es una **propuesta**: todavía no hay implementación verificada, y los umbrales numéricos son metas del piloto, no mandatos de una norma.

Objetivo. Especificar los requisitos del sistema de salas de chat seguras, identificar las propiedades de seguridad que debe cumplir y seleccionar las técnicas que mitigan los riesgos ya identificados, de modo que cada decisión se pueda verificar con una prueba.

2. Contexto y alcance

Alcance: administración de salas, mensajes de texto en tiempo real, multimedia PNG/JPEG, conexión única por identidad, criptografía, detección de contenido sospechoso, auditoría y alertas.

Arquitectura propuesta: cliente web, consola administrativa, APIs, WebSocket, base de datos relacional, almacenamiento de sesiones, analizador aislado y registros separados.

3. Actividad 1: Requisitos funcionales

Un requisito funcional dice **qué debe hacer el sistema**. Se cubren todos los aspectos mínimos del laboratorio: autenticación del administrador, administración de salas, configuración de participantes, acceso con identificador y clave, un solo dispositivo por usuario, mensajes, transferencia de archivos, validación multimedia, detección de archivos sospechosos, alertas y gestión de sesiones.

Código	Requisito funcional	Descripción	Actor	Prioridad
RF-01	Inicio administrativo	Permitir iniciar sesión administrativa solo después de validar credenciales y código TOTP.	Administrador	Alta
RF-02	Gestión de salas	Permitir al administrador autorizado crear, modificar, consultar y cerrar salas. Una sala cerrada no admite ingresos.	Administrador	Alta
RF-03	Configuración de sala	Definir para cada sala un identificador independiente, una clave, un aforo máximo y una modalidad (texto o multimedia).	Administrador	Alta
RF-04	Ingreso de participantes	Admitir al participante solo si la sala está activa, la clave es correcta, está identificado y hay aforo disponible.	Participante / backend	Alta
RF-05	Identidad estable (propuesta)	Asignar un identificador estable que asocie sesiones y eventos, sin presentarlo como prueba de identidad física.	Participante / backend	Media
RF-06	Texto en tiempo real	Permitir a los miembros activos enviar y recibir mensajes dentro de su sala.	Participante	Alta
RF-07	Conexión única	Impedir dos conexiones simultáneas para la misma identidad.	Backend	Alta
RF-08	Cierre de sesión	Cerrar la conexión y revocar el acceso asociado.	Administrador / participante	Alta
RF-09	Carga de imágenes	Recibir imágenes PNG o JPEG en una sala multimedia y dejarlas en cuarentena antes de publicarlas.	Participante / analizador	Alta

Código	Requisito funcional	Descripción	Actor	Prioridad
RF-10	Clasificación multimedia	Clasificar cada imagen como aprobada, rechazada, sospechosa o análisis fallido. Solo se publica la aprobada.	Analizador	Alta
RF-11	Descarga autorizada (propuesta)	Permitir descargar una imagen solo a miembros autorizados de su sala.	Participante / backend	Media
RF-12	Registro de seguridad	Registrar eventos con identidad técnica, fecha, acción, objeto y resultado.	Servicios internos	Alta
RF-13	Alertas	Alertar sobre intentos reiterados, archivos sospechosos, alteración de auditoría y eventos de alto riesgo.	Servicios / administrador	Alta
RF-14	Consulta de eventos (propuesta)	Permitir al administrador autorizado consultar eventos sin poder alterar las evidencias.	Administrador	Media
RF-15	Gestión de participantes (propuesta)	Permitir al administrador autorizado consultar los participantes activos de una sala y expulsar a uno, revocando su sesión y liberando su aforo.	Administrador	Media

4. Actividad 2: Requisitos no funcionales

Un requisito no funcional fija **qué tan bien** debe funcionar el sistema. Cada uno tiene un criterio medible y una prueba. Las cifras parten del supuesto del piloto (hasta 50 usuarios simultáneos) y de los indicadores K08 a K10 del Laboratorio 2; son metas de diseño que se confirman o se ajustan con las mediciones.

Código	Atributo	Requisito no funcional	Criterio de aceptación	Prueba
RNF-01	Rendimiento (mensajes)	Entregar los mensajes de texto a los miembros de la sala con baja latencia.	Percentil 95 de entrega < 2 s con 50 usuarios simultáneos y sin caída del servicio (K08).	Prueba de carga con 50 clientes simulados.
RNF-02	Rendimiento (multimedia)	Analizar y clasificar las imágenes sin bloquear la mensajería.	Imagen de hasta 5 MB clasificada en ≤ 10 s (percentil 95); el chat de texto no se degrada mientras se analiza.	Subida de 100 imágenes con chat activo.
RNF-03	Rendimiento (acceso)	Autenticar al administrador (contraseña y TOTP) sin demoras perceptibles pese al costo de Argon2id.	Inicio de sesión ≤ 2 s (percentil 95) en el entorno de pruebas.	100 inicios de sesión medidos.
RNF-04	Disponibilidad	Mantener disponibles los servicios de comunicación durante el piloto.	Disponibilidad mensual $\geq 99\,\%$ (a lo sumo 7,2 h de indisponibilidad al mes), medida con una comprobación de estado cada minuto.	Monitoreo continuo y reporte mensual.

Código	Atributo	Requisito no funcional	Criterio de aceptación	Prueba
RNF-05	Escalabilidad	Crecer en usuarios añadiendo instancias, sin cambiar el código.	Con 100 usuarios y el doble de instancias, el percentil 95 de entrega < 3 s. El estado de sesión vive en el almacén compartido, no en la memoria de una instancia.	Prueba de carga escalonada: 50, 75 y 100 usuarios.
RNF-06	Usabilidad	Que un participante entre a una sala y escriba con pasos simples y errores comprensibles.	Con al menos 10 usuarios de prueba, 90 % ingresa en ≤ 3 pasos y ≤ 60 s; los mensajes de error no revelan detalles internos.	Prueba de usabilidad con tareas guiadas.
RNF-07	Mantenibilidad	Mantener módulos separados (API, tiempo real, analizador, auditoría) y pruebas automatizadas.	Cobertura de pruebas $\geq$ 70 % en los módulos de seguridad; 0 hallazgos críticos de SAST abiertos; API documentada con OpenAPI.	Reporte de cobertura y del pipeline.
RNF-08	Interoperabilidad	Funcionar en los navegadores habituales y con estándares abiertos.	Funciona en las dos últimas versiones estables de Chrome, Firefox y Edge; API REST con JSON y WebSocket estándar (RFC 6455) sobre TLS.	Lista de verificación en los tres navegadores.
RNF-09	Confiabilidad	Entregar cada mensaje a los miembros conectados una sola vez y en orden por sala.	En 10 000 mensajes de prueba: $\geq$ 99,9 % entregados, sin duplicados ni desorden dentro de la sala.	Prueba automatizada con contador de secuencia.
RNF-10	Recuperación ante fallos	Restaurar el servicio y los datos tras una falla o incidente.	Tiempo de recuperación (RTO) ≤ 2 h y pérdida máxima de datos (RPO) ≤ 24 h, con respaldo diario cifrado.	Un simulacro de restauración por iteración.
RNF-11	Capacidad de monitoreo	Medir y alertar sobre el estado del sistema.	Se publican métricas de latencia, conexiones, errores y rechazos; una alerta de saturación o de falta de auditoría llega en ≤ 5 min (K09).	Provocar saturación y cortar el envío de logs.
RNF-12	Auditabilidad y retención	Conservar la evidencia el tiempo suficiente y consultable.	Los registros de seguridad se conservan al menos 90 días con hora sincronizada; la consulta de un evento tarda ≤ 5 s.	Revisión de retención y consulta de 20 eventos.

5. Actividad 3: Requisitos de seguridad

Un requisito de seguridad dice **cómo debe protegerse lo que hace el sistema**. Cada obligación se verifica en el servidor (los controles del navegador no sustituyen la validación), se liga con un activo y un riesgo del Laboratorio 2 y tiene un mecanismo de verificación. El detalle de cada prueba está en la sección **??**.

Código	Requisito de seguridad	Activo y riesgo	RF	Verificación
RS-01	**MFA y credenciales.** Exigir contraseña y TOTP al administrador; guardar contraseñas con Argon2id y sal única; limitar intentos y no registrar secretos.	A01 Credenciales del administrador; R01 Fuerza bruta	RF-01	Sin TOTP no accede; 20 intentos en un minuto activan el bloqueo.
RS-02	**Tokens revocables.** Aceptar solo tokens con firma, emisor, audiencia y vigencia válidos, y cuyo identificador no esté revocado.	A02 API de autenticación; R02 Suplantación de identidad	RF-01, RF-04, RF-08	Tokens alterados, vencidos y revocados se rechazan por HTTP y WebSocket.
RS-03	**Autorización administrativa.** Verificar en el servidor identidad, rol y permiso en cada operación; denegar y registrar lo no autorizado.	A03 API de gestión de salas; R03 Cambios no autorizados	RF-02, RF-03, RF-14, RF-15	Un participante intenta crear, editar y cerrar una sala: se deniega.
RS-04	**Salas privadas.** Generar claves aleatorias, guardar derivaciones resistentes (no la clave), compararlas de forma segura y limitar intentos.	A04 Claves de salas; R04 Acceso a salas privadas	RF-03, RF-04	20 claves erróneas por minuto: se limita; tras rotar, la anterior falla.
RS-05	**Mínimo privilegio.** Separar roles y servicios, otorgar solo los permisos necesarios y denegar por defecto.	A05 Roles y permisos; R05 Escalada de privilegios	RF-02 a RF-15	Un campo `rol` manipulado se rechaza; se revisa la matriz de permisos.
RS-06	**Sesión única.** Crear, sustituir y cerrar conexiones de forma atómica según una política auditable.	A06 Sesiones y dispositivos; R06 Secuestro o duplicación	RF-05, RF-07, RF-08	100 pares de conexiones simultáneas: solo una queda activa.
RS-07	**Tránsito cifrado.** Aceptar solo HTTPS y WSS sobre TLS 1.3 con certificado válido y rechazar transporte inseguro.	A07 Conexiones WebSocket; R07 Intercepción del canal	RF-01, RF-04, RF-06, RF-09 a RF-11	`ws://` y HTTP se rechazan; la captura no muestra datos en claro.
RS-08	**Mensajes verificables.** Vincular cada mensaje con su sala y con la identidad autenticada; usar cifrado autenticado y rechazar repeticiones o alteraciones.	A08 Mensajes de chat; R08 Alteración o suplantación	RF-06	Remitente falso se ignora; mensaje alterado falla; repetido se entrega una vez.
RS-09	**Gestión de claves.** Separar claves por propósito y ambiente, restringir su acceso, excluirlas del código y de los logs, y poder rotarlas y revocarlas.	A09 Claves criptográficas; R09 Filtración de claves	RF-01, RF-03, RF-06, RF-09 a RF-12	Escaneo del historial: cero secretos activos; la clave rotada deja de servir.
RS-10	**Carga segura.** Validar tamaño, extensión, tipo, firma y decodificación de PNG/JPEG; mantener cuarentena y analizar malware.	A10 API de carga de archivos; R10 Carga de archivo malicioso	RF-09, RF-10	Ejecutable renombrado .png, imagen truncada y archivo antimalware inocuo: no se publican.
RS-11	**Descarga autorizada.** Verificar membresía y pertenencia del archivo; limitar alcance y vigencia de los enlaces firmados.	A11 Almacenamiento multimedia; R11 Descarga de otra sala	RF-11	No miembro: denegado; enlace vencido: falla.
RS-12	**Esteganálisis.** Analizar PNG/JPEG en un módulo aislado, registrar la puntuación junto al hash del archivo y no publicar ante sospecha, duda o fallo.	A12 Módulo de esteganografía; R12 Contenido oculto	RF-09, RF-10	Con muestras etiquetadas: fallos $\leq 5\,\%$ y bloqueo de limpias $\leq 10\,\%$; el fallo retiene.

Código	Requisito de seguridad	Activo y riesgo	RF	Verificación
RS-13	**Auditoría íntegra.** Enviar eventos a un destino separado con acceso restringido y hash encadenado; detectar y alertar alteraciones.	A13 Registros de auditoría; R13 Manipulación de auditoría	RF-12 a RF-14	Borrar o editar con la cuenta del chat se deniega; cortar el envío genera alerta.
RS-14	**Prevención de inyección SQL.** Usar consultas parametrizadas, validar tipo, longitud y formato, y aplicar SAST y DAST.	A14 Base de datos; R14 Inyección SQL	RF-01 a RF-15	Entradas con comillas y tipos inválidos no alteran la consulta; sin críticos en SAST/DAST.
RS-15	**Disponibilidad.** Aplicar límites de solicitudes, cargas, aforo y conexiones, tiempos máximos, monitoreo y rechazo controlado.	A15 Servidor backend y APIs; R15 Denegación de servicio	RF-01 a RF-15	Carga de 50 usuarios más clientes abusivos: se rechaza el exceso y se atiende a los legítimos.
RS-16	**Privacidad y protección en reposo (nuevo).** Cifrar en reposo archivos y datos persistidos con claves separadas, recolectar solo los datos necesarios, excluir mensajes y tokens de los logs y aplicar una retención definida.	A11 Almacenamiento multimedia, A09 Claves; R11, R09	RF-06, RF-09, RF-11, RF-12	Leer el almacenamiento directamente no da contenido legible; los logs no contienen mensajes ni tokens.
RS-17	**Respuesta a incidentes y recuperación (nuevo).** Contar con un procedimiento para contener (revocar tokens, cerrar salas, rotar claves), preservar evidencia y restaurar desde respaldos cifrados probados.	A13 Auditoría, A15 Backend; R13, R15, R09	RF-08, RF-12, RF-13	Simulacro: contención y restauración dentro de RTO $\leq$ 2 h y RPO $\leq$ 24 h.

Por qué se añadieron RS-16 y RS-17. El laboratorio pide analizar la *privacidad* y la *resiliencia*, y pide *respuesta ante eventos sospechosos*. Esos temas aparecían de forma dispersa; ahora cada uno tiene una obligación propia y verificable.

6. Actividad 4: Propiedades de seguridad

Las propiedades identifican los atributos que deben preservarse frente a las amenazas. Se analizan once: tres básicas (tríada C-I-D), tres de control de identidad y acceso (AAA) y cinco complementarias.

6.1. Matriz de análisis de propiedades

Propiedad	Aplicación en el sistema	Amenaza relacionada	Requisitos
Básicas – Tríada C-I-D			
Confidencialidad	Solo los miembros de una sala ven sus mensajes e imágenes; las claves y credenciales no se exponen.	Intercepción del canal (R07), acceso a salas privadas (R04), descarga de otra sala (R11), filtración de claves (R09).	RS-04, RS-07, RS-09, RS-11, RS-16
Integridad	Mensajes, configuración de salas, archivos publicados y registros no cambian sin autorización.	Alteración de mensajes (R08), cambios no autorizados (R03), inyección SQL (R14), manipulación de auditoría (R13).	RS-03, RS-08, RS-13, RS-14

Propiedad	Aplicación en el sistema	Amenaza relacionada	Requisitos
Disponibilidad	Las salas siguen operando aunque alguien intente saturar o duplicar conexiones.	Denegación de servicio (R15), carga de archivos que agotan recursos (R10), secuestro de sesiones (R06).	RS-06, RS-10, RS-15, RS-17
Control de identidad y acceso – AAA			
Autenticación	Verificar quién es el administrador (contraseña + TOTP) y el participante (identidad y clave de sala) antes de dar acceso.	Fuerza bruta (R01), suplantación de identidad (R02), adivinar claves de sala (R04).	RS-01, RS-02, RS-04
Autorización	Cada operación se valida en el servidor según rol, membresía y modo de la sala.	Cambios no autorizados (R03), escalada de privilegios (R05), descarga de otra sala (R11).	RS-03, RS-05, RS-11
Auditoría / contabilización	Cada acción relevante queda registrada con actor, fecha, objeto y resultado, en un destino separado.	Manipulación de auditoría (R13): sin evidencia no se detecta ninguno de los otros riesgos.	RS-13, RS-17
Complementarias			
Autenticidad	El remitente de un mensaje sale de la sesión del servidor; el archivo publicado es el mismo que se analizó (hash).	Falsificar el remitente (R08), token robado o falsificado (R02).	RS-02, RS-08, RS-12
No repudio (parcial)	La identidad estable y los registros encadenados permiten atribuir acciones a una cuenta, pero no prueban autoría ante terceros.	Un usuario o administrador niega haber enviado un mensaje o cambiado una sala (R08, R13).	RS-06, RS-08, RS-13
Trazabilidad	Poder reconstruir quién hizo qué y cuándo, con hora sincronizada y un identificador por sesión.	Sesiones duplicadas o ajenas (R06), borrado de evidencias (R13).	RS-06, RS-13
Privacidad	Recolectar pocos datos, cifrarlos en reposo, no escribir mensajes ni tokens en logs y limitar la retención.	Exposición del almacenamiento (R11), filtración de claves (R09), logs con datos sensibles (R13).	RS-09, RS-13, RS-16
Resiliencia	Resistir ataques o fallas, degradar de forma controlada y recuperarse dentro de RTO y RPO.	Denegación de servicio (R15), archivos masivos encadenados con saturación (R10), pérdida de evidencia (R13).	RS-15, RS-17

Sobre el no repudio. Se analiza, pero no se promete como garantía. AES-GCM, HMAC o SHA-256 por sí solos no prueban la autoría de una persona ante terceros, porque quien comparte la clave puede producir el mismo resultado. Con la identidad estable (RF-05) y la auditoría íntegra (RS-13) se logra **trazabilidad y responsabilidad** a nivel de cuenta: es un no repudio *parcial*. Para un no repudio fuerte haría falta que cada participante firme sus mensajes con una clave privada propia; se deja como mejora futura.

6.2. Propiedades por requisito funcional

La asignación de confidencialidad (C), integridad (I) y disponibilidad (D) se fundamenta en los activos y efectos que cada requisito debe proteger.

RF	C	I	D	Complementarias	Justificación
RF-01	•	•	•	Autenticación, autorización, trazabilidad	Protege credenciales, sesión y acceso a la consola.
RF-02		•	•	Autorización, trazabilidad, responsabilidad	Protege cambios y disponibilidad de las salas.
RF-03	•	•		Autorización, trazabilidad	Protege la clave y la configuración.
RF-04	•	•	•	Autenticación, autorización, trazabilidad	Valida secreto, identidad, estado y aforo.
RF-05	•	•		Autenticación, responsabilidad	Asocia correctamente sesiones y eventos.
RF-06	•	•	•	Autenticidad, autorización, privacidad	Protege contenido, origen y entrega.
RF-07		•	•	Autenticación, trazabilidad	Mantiene un estado concurrente consistente.
RF-08	•	•		Autenticación, trazabilidad	Invalida el acceso y deja evidencia.
RF-09	•	•	•	Autorización, trazabilidad, resiliencia	Restringe la carga y conserva la cuarentena.
RF-10		•	•	Autenticidad, trazabilidad, auditabilidad	Hace reproducible la clasificación y falla cerrado.
RF-11	•	•	•	Autenticación, autorización, privacidad	Evita la exposición entre salas.
RF-12		•	•	Trazabilidad, auditabilidad, responsabilidad	Conserva evidencia atribuible.
RF-13		•	•	Trazabilidad, auditabilidad, resiliencia	Asegura una alerta correcta y oportuna.
RF-14	•	•	•	Autenticación, autorización, auditabilidad	Protege la consulta de eventos.
RF-15		•	•	Autorización, trazabilidad	Evita expulsiones indebidas y deja evidencia.

7. Actividad 5: Técnicas y mecanismos de seguridad

Se seleccionaron 19 técnicas, agrupadas en las seis categorías del laboratorio. Cada una indica el mecanismo concreto, los requisitos que satisface, la amenaza que mitiga y por qué se eligió.

ID	Categoría	Técnica y mecanismo	RS	Amenaza mitigada	Justificación
T01	Acceso	MFA con TOTP, Argon2id con sal única y bloqueo progresivo de intentos.	RS-01	Fuerza bruta y reutilización de contraseñas (R01).	Un segundo factor y un hash costoso encarecen el ataque, aunque la contraseña se filtre.
T02	Acceso	Tokens firmados con expiración corta, validación de firma, emisor, audiencia y lista de revocación; también en el *handshake* WebSocket.	RS-02, RS-06	Suplantación con token falso o robado (R02).	La vida corta limita el daño de un token robado y la revocación permite cerrarlo de inmediato.
T03	Acceso	RBAC en el servidor con denegación por defecto y revalidación del permiso en cada operación y mensaje.	RS-03, RS-05	Cambios no autorizados y escalada de privilegios (R03, R05).	Los controles de la interfaz se pueden saltar; solo el servidor es confiable.

ID	Categoría	Técnica y mecanismo	RS	Amenaza mitigada	Justificación
T04	Acceso	Claves de sala aleatorias (mínimo 128 bits), hash resistente, IDs no predecibles y límite de intentos por sala, identidad y origen.	RS-04	Adivinar sala y clave (R04).	Una clave aleatoria larga no se adivina, y el límite frena la repetición.
T05	Acceso	Cuentas y servicios separados (backend, analizador, auditoría, base de datos) con permisos mínimos.	RS-05, RS-13	Escalada de privilegios y borrado de evidencia (R05, R13).	Si un componente cae, no hereda los permisos de los demás.
T06	Acceso	Sesión única con operación atómica en el almacén de sesiones y cierre del WebSocket al revocar.	RS-06	Duplicación o secuestro de sesión (R06).	Comprobar y registrar en pasos separados permite carreras; una sola operación atómica las evita.
T07	Comunicaciones	HTTPS y WSS con TLS 1.3, certificado válido, HSTS y validación del encabezado *Origin*.	RS-07	Intercepción o alteración del tráfico (R07).	Protege credenciales y mensajes en tránsito con un estándar vigente (RFC 8446).
T08	Comunicaciones	AES-GCM con *nonce* único, remitente tomado de la sesión del servidor, número de secuencia por sala e identificadores únicos.	RS-08	Alteración, repetición y falsa atribución (R08).	El cifrado autenticado detecta cambios y la secuencia descarta repeticiones.
T09	Comunicaciones	Gestor de secretos con acceso por identidad de servicio, claves por propósito y sala, versionadas y rotables.	RS-09	Filtración de claves (R09).	Saca los secretos del código y limita el alcance de una filtración.
T10	Multimedia	Lista permitida PNG/JPEG, validación de firma y decodificación, tamaño máximo, nombres aleatorios, cuarentena y antimalware.	RS-10	Archivo malicioso disfrazado de imagen (R10).	Un archivo se acepta por su contenido real y no por su extensión.
T11	Multimedia	Verificación de membresía en cada descarga y enlaces firmados de vida corta con identificadores aleatorios.	RS-11	Descarga de archivos de otra sala (R11).	El enlace por sí solo no autoriza: el servidor comprueba la pertenencia.
T12	Multimedia	Esteganálisis estadístico y estructural en módulo aislado, umbrales documentados, decisión ligada al hash SHA-256 y retención ante duda o fallo.	RS-12	Contenido oculto en imágenes (R12).	Ningún detector es perfecto; por eso se mide y ante la duda no se publica.
T13	Operativa	Registros en destino separado con credencial de solo inserción, hash encadenado, hora sincronizada y alerta por silencio.	RS-13	Alteración de evidencias (R13).	Si el chat no puede borrar los logs, un intruso no puede ocultar sus pasos.

ID	Categoría	Técnica y mecanismo	RS	Amenaza mitigada	Justificación
T14	Aplicaciones	Consultas parametrizadas, validación de tipo, longitud y formato en el servidor, usuario de base de datos con mínimo privilegio y errores sin detalles internos.	RS-14	Inyección SQL (R14).	Separa los datos de la consulta y limita el daño si algo falla.
T15	Operativa	Límites de tasa por identidad y origen, tamaño máximo de mensaje, cupos de conexiones, colas acotadas, monitoreo y alertas de saturación.	RS-15	Denegación de servicio (R15).	Rechaza el exceso de forma controlada y protege a los usuarios legítimos.
T16	Comunicaciones	Cifrado en reposo con claves separadas de los datos, minimización, exclusión de contenido en logs y retención definida.	RS-16	Exposición del almacenamiento y de los logs (R11, R09).	Si alguien lee el disco o la copia, no obtiene contenido legible.
T17	Desarrollo	SAST, análisis de dependencias (SCA) y escaneo de secretos en cada *commit* y *pull request*.	RS-09, RS-14	Inyección, bibliotecas vulnerables y secretos en el código (R14, R09).	Detecta fallas antes de que lleguen a producción, cuando corregirlas es barato.
T18	Desarrollo	Revisión de código por pares con lista de seguridad (OWASP), DAST y pruebas de seguridad automatizadas (casos negativos) antes de liberar.	RS-03, RS-14, RS-15	Errores de lógica y de autorización que no ve el análisis estático (R03, R14).	Las pruebas dinámicas atacan el sistema en ejecución, como lo haría un intruso.
T19	Operativa	Plan de respuesta a incidentes, respaldos diarios cifrados y simulacro de restauración.	RS-17	Pérdida de servicio, claves o evidencias (R15, R13, R09).	Reduce el tiempo de recuperación y asegura que el respaldo realmente funciona.

7.1. Plan de pruebas del esteganálisis

El laboratorio exige reconocer que detectar contenido oculto **no es infalible**. El módulo (T12) se evalúa con imágenes benignas y manipuladas, y se informan los errores en lugar de afirmar una detección perfecta.

Elemento	Propuesta
Conjunto de prueba	Al menos 100 imágenes limpias y 100 alteradas por formato (PNG y JPEG) y por técnica, tomadas de fuentes distintas de las usadas para ajustar el detector.
Manipulaciones	PNG: ocultar datos en los bits menos significativos. JPEG: ocultar datos en los coeficientes de la transformada. Con varias cargas (pequeña, media y grande) para ver dónde falla.
Falso negativo	Imagen alterada que se acepta o se marca como dudosa. Los resultados dudosos **cuentan como fallo** para no mejorar la cifra por abstención. Meta: $\leq 5\,\%$ por formato (K06).
Falso positivo	Imagen limpia sospechosa o dudosa y, por tanto, bloqueada. Meta: $\leq 10\,\%$ por formato (K07).
Rendimiento	Tiempo por imagen ≤ 10 s (percentil 95) sin afectar el chat de texto (RNF-02). Si se excede, el análisis se encola y la imagen queda retenida.
Falla cerrada	Si el módulo no responde o falla, la imagen no se publica y se genera una alerta.

7.2. Límites que hay que decir en voz alta

- El **antimalware** no garantiza detectar información oculta en una imagen.
- **SHA-256** detecta cambios solo si se compara con una referencia confiable; por sí solo no detecta esteganografía ni autentica al remitente.
- El **esteganálisis** produce falsos positivos y falsos negativos, y las cargas muy pequeñas o técnicas no cubiertas pueden pasar. Por eso, ante duda o fallo, la imagen no se publica.
- Una **clave de sala o un enlace firmado** no reemplazan la verificación de membresía en el servidor.
- **TLS no es cifrado de extremo a extremo**: el servidor debe ver la imagen para analizarla.

8. Actividad 6: Zero Trust, Secure by Design y Shift Left Security

Los tres enfoques se concretan en prácticas con una fase del ciclo de desarrollo y una evidencia que demuestra su cumplimiento.

Enfoque	Práctica propuesta	Fase	Evidencia	RS
Zero Trust	Verificar identidad, token, rol y membresía en **cada** solicitud HTTP y mensaje WebSocket; no confiar en el navegador ni en la red.	Diseño e implementación	Pruebas de autenticación y autorización; matriz de pruebas por rol.	RS-02, RS-03
Zero Trust	Mínimo privilegio y segmentación: cuentas separadas para backend, analizador, auditoría y base de datos.	Diseño y despliegue	Matriz de permisos; intento fallido de borrar logs con la cuenta del chat.	RS-05, RS-13
Zero Trust	Suponer la brecha: analizador aislado, auditoría de solo inserción, cuarentena y cifrado en reposo.	Diseño	Diagrama de arquitectura; pruebas de aislamiento.	RS-12, RS-13, RS-16
Zero Trust	Sesiones de vida corta con revalidación y revocación inmediata.	Implementación	Pruebas con token vencido y revocado.	RS-02, RS-06
Secure by Design	Partir del análisis de riesgos (Laboratorio 2) y derivar cada RS desde un riesgo antes de programar.	Análisis	Esta especificación y la matriz de trazabilidad.	Todos
Secure by Design	Denegación por defecto y separación de componentes en la arquitectura.	Diseño	Diagramas y matriz de roles aprobados.	RS-03, RS-05
Secure by Design	Fallar cerrado: ante duda o fallo del análisis, la imagen no se publica.	Diseño e implementación	Pruebas de RS-12 con muestras etiquetadas.	RS-10, RS-12
Secure by Design	Usar criptografía estándar (TLS 1.3, AES-GCM, Argon2id) y gestor de secretos; no inventar algoritmos.	Diseño	Especificación y revisión de la configuración.	RS-01, RS-07, RS-08, RS-09
Shift Left	SAST, SCA y escaneo de secretos en cada *commit* y *pull request*.	Implementación	Reportes del pipeline; 0 críticos abiertos (K10).	RS-09, RS-14

Enfoque	Práctica propuesta	Fase	Evidencia	RS
Shift Left	Escribir los criterios de aceptación y las pruebas negativas de cada RS antes de implementarlo.	Análisis y diseño	Tabla de verificación (sección **??**).	Todos
Shift Left	Revisión de código por pares con lista de verificación de seguridad (OWASP).	Implementación	Actas o comentarios de revisión por pull request.	RS-03, RS-14
Shift Left	DAST, pruebas de carga y de esteganálisis en el entorno de pruebas antes de liberar.	Pruebas y entrega	Reportes DAST, de carga y de errores del detector (K06 a K08).	RS-12, RS-14, RS-15

8.1. Controles de ISO/IEC 27001:2022 (Anexo A)

Control	Nombre	Justificación en KunturChat	Riesgos / RS
A.5.15	Control de acceso	Define quién accede a qué (administrador, participante, servicio) y se aplica con RBAC y denegación por defecto.	R03, R04, R05, R11; RS-03, RS-04, RS-05, RS-11
A.8.5	Autenticación segura	Exige TOTP, tokens firmados y revocables y sesión única; es la base de RF-01 y RF-07.	R01, R02, R06; RS-01, RS-02, RS-06
A.8.24	Uso de criptografía	Respalda TLS 1.3, AES-GCM, Argon2id y la gestión y rotación de claves.	R07, R08, R09; RS-07, RS-08, RS-09, RS-16
A.8.28	Codificación segura	Respalda consultas parametrizadas, validación en servidor, revisión de código y SAST.	R14; RS-14
A.8.29	Pruebas de seguridad en desarrollo y aceptación	Respalda DAST, pruebas de carga, plan de esteganálisis y criterios de aceptación medibles.	R10, R12, R15; RS-10, RS-12, RS-15
A.8.16	Actividades de monitoreo	Respalda el registro, las alertas y el monitoreo de saturación.	R13, R15; RS-13, RS-15

8.2. Prácticas de ISO/IEC 27034 (seguridad de aplicaciones)

La norma ISO/IEC 27034 organiza la seguridad de una aplicación mediante controles de seguridad de la aplicación, un nivel de confianza objetivo y actividades de seguridad en cada fase del ciclo de vida.

Práctica	Aplicación en KunturChat	Riesgos / RS
Controles de seguridad de la aplicación (ASC)	Cada RS es un control con una verificación medible: la tabla de la sección **??** hace de lista de controles y de sus pruebas.	Todos
Nivel de confianza objetivo	El riesgo residual de cada ficha (R01–R15) fija el nivel que se espera alcanzar; solo se declara logrado si pasa la prueba.	R01–R15
Seguridad en el ciclo de vida de la aplicación	Se asignan actividades de seguridad a cada fase: análisis (riesgos y RS), diseño (arquitectura), implementación (SAST, SCA, revisión) y pruebas (DAST, carga).	RS-09, RS-14, RS-15
Validación y verificación de los controles	Los resultados de las pruebas quedan como evidencia revisable antes de liberar; si una prueba falla, el residual no se acredita.	RS-01 a RS-17

Las normas se usan como orientación: no se declara conformidad ni certificación.

9. Actividad 7: Matriz de trazabilidad

La matriz relaciona cada riesgo del Laboratorio 2 con los requisitos de seguridad, las propiedades, las técnicas y el riesgo residual objetivo (Pr $\times$ Ir). Los valores residuales son metas: se confirman solo si pasan las pruebas.

Riesgo identificado	Inh.	RS	RF	Propiedades	Técnicas	Residual	Política
R01 Fuerza bruta contra el administrador	20 Alto	RS-01	RF-01	Confidencialidad; autenticación	T01	8 Medio-Bajo	POL01
R02 Suplantación en la API de autenticación	20 Alto	RS-02	RF-01, 04, 08	Confidencialidad, integridad; autenticación, autenticidad	T02	8 Medio-Bajo	POL02
R03 Modificación no autorizada de salas	16 Alto	RS-03, RS-05	RF-02, 03, 14, 15	Integridad; autorización	T03, T05, T18	6 Medio-Bajo	POL03
R04 Acceso a salas privadas	20 Alto	RS-04	RF-03, 04	Confidencialidad; autenticación	T04	8 Medio-Bajo	POL01
R05 Escalada de privilegios	15 Medio-Alto	RS-05, RS-03	RF-02 a 15	Confidencialidad, integridad; autorización	T03, T05	6 Medio-Bajo	POL03
R06 Secuestro o duplicación de sesiones	16 Alto	RS-06, RS-02	RF-05, 07, 08	Integridad, disponibilidad; trazabilidad, no repudio (parcial)	T06, T02	6 Medio-Bajo	POL02
R07 Intercepción del canal WebSocket	15 Medio-Alto	RS-07	RF-01, 04, 06, 09 a 11	Confidencialidad, integridad; autenticidad	T07	4 Bajo	POL04
R08 Alteración o suplantación de mensajes	15 Medio-Alto	RS-08	RF-06	Integridad; autenticidad, no repudio (parcial)	T08	4 Bajo	POL04
R09 Filtración de claves criptográficas	15 Medio-Alto	RS-09, RS-16, RS-17	RF-01, 03, 06, 09 a 12	Confidencialidad, integridad; privacidad	T09, T16, T17, T19	6 Medio-Bajo	POL04
R10 Carga de archivo malicioso	16 Alto	RS-10	RF-09, 10	Integridad, disponibilidad; resiliencia	T10, T17	8 Medio-Bajo	POL06
R11 Descarga de archivos de otra sala	16 Alto	RS-11, RS-16	RF-11	Confidencialidad; autorización, privacidad	T11, T16	6 Medio-Bajo	POL03, POL06
R12 Contenido oculto por esteganografía	12 Medio-Alto	RS-12	RF-09, 10	Integridad; autenticidad, auditabilidad	T12	6 Medio-Bajo	POL06
R13 Manipulación de auditoría	12 Medio-Alto	RS-13, RS-17	RF-12 a 14	Integridad, disponibilidad; auditoría, trazabilidad, no repudio (parcial)	T13, T05, T19	4 Bajo	POL07
R14 Inyección SQL	16 Alto	RS-14	RF-01 a 15	Confidencialidad, integridad, disponibilidad; autorización	T14, T17, T18	6 Medio-Bajo	POL05
R15 Denegación de servicio (DoS)	16 Alto	RS-15, RS-17	RF-01 a 15	Disponibilidad; resiliencia	T15, T19	8 Medio-Bajo	POL08

Bibliografía

- Proyecto integrador: requisitos originales, arquitectura, activos, riesgos y políticas.
- Análisis y tratamiento de riesgos de KunturChat (Laboratorio 2, versión 2.0).
- ISO/IEC. (2022). *ISO/IEC 27001:2022. Information security management systems – Requirements*.
- ISO/IEC. (2011). *ISO/IEC 27034-1:2011. Application security – Part 1: Overview and concepts*.
- Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *Zero Trust Architecture*. NIST SP 800-207.
- OWASP Foundation. *Cheat Sheet Series* (sesiones, contraseñas, WebSocket, inyección SQL, subida de archivos y registros). `https://cheatsheetseries.owasp.org`
- Rescorla, E. (2018). *The Transport Layer Security Protocol Version 1.3*. RFC 8446.
- Fette, I. y Melnikov, A. (2011). *The WebSocket Protocol*. RFC 6455.